

Gobuster

Enumeração

O que é o Gobuster

Gobuster é uma ferramenta de enumeração (o primeiro passo dentro de um CTF)

A atividade de enumeração significa descobrir qual a estrutura de um domínio que nossa equipe vai atacar. Existem muitos endpoints que são visíveis e acessíveis. Outros ficam escondidos como forma dos desenvolvedores proverem manutenção nos seus sites, uma vulnerabilidade branda. Outros mais raros nem são de conhecimento dos desenvolvedores, são uma vulnerabilidade forte. São nesses locais invisíveis que vamos procurar nossas brechas de segurança.

Instalação do Gobuster

- 1) Se você está no Kali
 - a) `sudo apt install gobuster`
- 2) Se você está no MAC
 - a) `brew install gobuster`
- 3) Se você está no Windows
 - a) basta apertar as teclas alt+F4 😊

Como explorar o programa

gobuster -h (é a página inicial de qualquer programa raiz do Kali)

Comandos disponíveis

dir Uses directory/file enumeration mode

dns Uses DNS subdomain enumeration mode

fuzz Uses fuzzing mode. Replaces the keyword FUZZ in the URL, Headers and the request body

gcs Uses gcs bucket enumeration mode

help Help about any command

s3 Uses aws bucket enumeration mode

tftp Uses TFTP enumeration mode

version shows the current version

vhost Uses VHOST enumeration mode (you most probably want to use the IP address as the URL parameter)

Como explorar o programa

gobuster -h (é a página inicial de qualquer programa raiz do Kali)

Comandos disponíveis

dir Uses directory/file enumeration mode

dns Uses DNS subdomain enumeration mode

fuzz Uses fuzzing mode. Replaces the keyword FUZZ in the URL, Headers and the request body

gcs Uses gcs bucket enumeration mode

help Help about any command

s3 Uses aws bucket enumeration mode

tftp Uses TFTP enumeration mode

version shows the current version

vhost Uses VHOST enumeration mode (you most probably want to use the IP address as the URL parameter)

Flags:

--debug	Enable debug output
--delay duration	Time each thread waits between requests (e.g. 1500ms)
-h, --help	help for gobuster
--no-color	Disable color output
--no-error	Don't display errors
-z, --no-progress	Don't display progress
-o, --output string	Output file to write results to (defaults to stdout)

Flags:

-p, --pattern string	File containing replacement patterns
-q, --quiet	Don't print the banner and other noise
-t, --threads int	Number of concurrent threads (default 10)
-v, --verbose	Verbose output (errors)
-w, --wordlist string	Path to the wordlist.
--wordlist-offset int	Resume from a given position in the wordlist (defaults to 0)

Use "gobuster [command] --help" for more information about a command.

Vamos vasculhar um pouco mais o gobuster

`gobuster [command] --help`

`gobuster dir --help`

Vamos vasculhar um pouco mais o gobuster

`gobuster [command] --help`

`gobuster dns --help`

Wordlist

O gobuster não trabalha sozinho, ele precisa de uma lista de palavras (wordlist). Essa lista de palavras podem ser senhas, e-mails, nome de usuário, nomes comuns de pasta (vejam estrutura de diretórios do Linux), etc

Por exemplo:

<https://raw.githubusercontent.com/teamstealthsec/wordlists/master/directory.txt>

é uma lista de nomes de diretórios que podemos usar para descobrir se um dado website possui algum desses diretórios.

Outro exemplo é o

<https://github.com/teamstealthsec/wordlists/blob/master/rockyou.txt.gz>

com milhões de senhas.

Vamos testar isso!!!

Vamos praticar!

- 1) Criar um arquivo de texto com a wordlist de diretórios que vimos anteriormente;
- 2) Montar o comando, nós já vimos mas eu vou passar de novo:
 - a) gobuster -help
 - b) gobuster [comando] --help == gobuster dir --help
 - c) gobuster dir -u (minha url) -w (minha wordlist)
- 3) Vamos fazer o ataque ao domínio seccom:

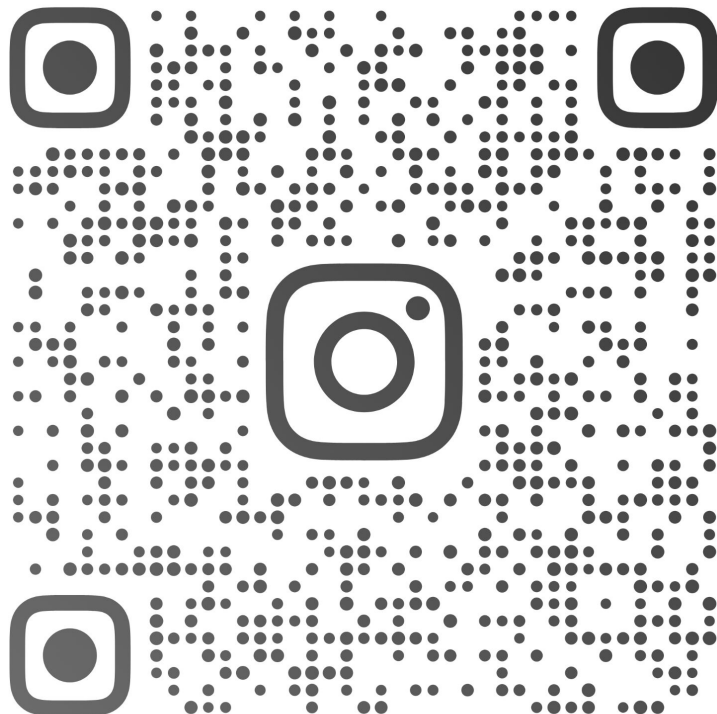
gobuster dir -u <https://seccom-ufsc.github.io/2024/> -w diretorios.txt

Vamos praticar!

- 1) Criar um arquivo de texto com as palavras admin, blog, root;
- 2) Montar o comando, nós já vimos mas eu vou passar de novo:
 - a) gobuster -help
 - b) gobuster [comando] --help == gobuster dir --help
 - c) gobuster -d (meu_dominio) -w (minha_wordlist) --wildcard
- 3) Vamos fazer o ataque ao domínio seccom:

```
gobuster dns -d stealthsecurity.io -w domains.txt --wildcard
```

--wildcard: essa flag lida com um status OK (200) mesmo quando o recurso não existe, é comum isso acontecer em websites que tem página personalizada para o status 404 (NOT FOUND) como o Github.



LIA.UFSC